James Summersill

C845 – WGU

FinSecure Corp Data Security and Systems Defense

A. Encryption Strategy Evaluation

A1. Data Protection Vulnerabilities and Risks

Two significant vulnerabilities emerge from the scenario:

1. Unencrypted Customer PII Stored in Clear Text
   The Finance server stores customer PII and financial records in clear text. As stated, "the on-premises Finance server maintains customer PII and financial records in a relational database that stores data in clear text on disk." This creates a high-impact risk because unauthorized access—whether through insider misuse, malware, or system compromise—would immediately expose sensitive data. The lack of encryption means that if an attacker gains access to the storage medium or the database itself, they can directly read and misuse sensitive personal and financial information without any additional barriers. This vulnerability significantly increases the risk of data breaches, identity theft, and regulatory non-compliance, which could lead to severe financial penalties and reputational damage.

2. Use of Legacy and Weak Protocols for Data in Transit
   The organization uses an internal FTP server with legacy protocols and allows TLS 1.0 on HTTPS connections. The artifacts note that HR and Finance "exchange payroll and employee data using an internal FTP server" and that customer data is transmitted over HTTPS connections that "allow multiple TLS protocol versions, including TLS 1.0." These outdated protocols are vulnerable to interception, downgrade attacks, and credential theft. Legacy FTP transmits data in plaintext, making it susceptible to eavesdropping and man-in-the-middle attacks. Similarly, TLS 1.0 is known to have multiple security weaknesses and is deprecated by industry standards. Continuing to use these protocols exposes sensitive data during transmission, undermining confidentiality and integrity.

A2. Recommended Cryptographic Methods

1. Implement Transparent Data Encryption (TDE) with AES-256 for Databases
   TDE encrypts data at rest using strong symmetric encryption, ensuring that stored PII is unreadable without proper keys. AES-256 is widely recognized for its robustness and is recommended by standards such as NIST. By encrypting the database files, even if physical storage or backups are compromised, the data remains protected. This method also simplifies compliance with data protection regulations by providing a strong technical control for data confidentiality.

2. Enforce TLS 1.2 or TLS 1.3 and Replace FTP with SFTP or FTPS
   Modern TLS versions provide secure encryption and authentication, while SFTP/FTPS ensures

encrypted file transfers. TLS 1.2 and 1.3 address vulnerabilities found in earlier versions and support stronger cipher suites and forward secrecy. Replacing FTP with secure alternatives prevents data from being transmitted in plaintext, protecting against interception and tampering during transit.

A2a. Justification for Confidentiality and Integrity

- AES-256 TDE protects confidentiality by ensuring that even if attackers access the storage layer, the data remains encrypted and unusable. It also supports integrity by preventing unauthorized modification of encrypted data. The encryption keys are managed securely, limiting access to authorized personnel only.
- TLS 1.2/1.3 and SFTP/FTPS ensure confidentiality by encrypting data in transit and integrity by preventing tampering or man-in-the-middle attacks. These protocols eliminate vulnerabilities inherent in FTP and deprecated TLS versions, thus maintaining secure communication channels.

B. System Architecture Vulnerability Analysis

B1. Identified Technical Vulnerabilities

1. Domain Admin Credentials Present on IT User Workstations
   The IT subnet includes standard user workstations that hold **Domain Admin–level access**. This configuration exposes the organization to significant risk because workstations are the most frequently compromised assets through phishing, malware, browser exploits, and credential-harvesting attacks. If a workstation containing Domain Admin credentials is compromised, an attacker can obtain full control of Active Directory, modify Group Policy, create privileged accounts, disable logging, and move laterally across the environment without restriction. A single compromised IT workstation could result in a **complete domain takeover**, loss of control over authentication systems, widespread ransomware deployment, or unauthorized access to sensitive data across the enterprise. This violates least-privilege principles and modern privileged-access standards.

2. Flat Network Architecture in the Data Center
   The data-center environment places multiple high-sensitivity systems—including customer records, finance VMs, accounting systems, and application servers—behind a single network gateway with no visible segmentation. This creates a flat network where all systems share the same trust boundary and can communicate freely without internal access controls. A compromise of any single system in the data center could allow an attacker to move laterally to more sensitive systems, including financial and customer-data repositories. This significantly increases the blast radius of an intrusion and undermines regulatory compliance requirements for isolating sensitive workloads.

3. Lack of Security Monitoring, IDS/IPS, and Traffic Inspection
   The architecture lacks dedicated security monitoring components, including intrusion detection/prevention systems (IDS/IPS), east-west traffic inspection, centralized log collection,

and endpoint detection and response (EDR). Without these controls, malicious activity inside the network may go undetected, and the organization lacks visibility into unauthorized access, lateral movement, or anomalous behavior. The absence of monitoring significantly delays detection and response to security incidents. Attackers can operate within the environment for extended periods, escalate privileges, exfiltrate data, or disrupt operations without triggering alerts. This increases the likelihood and severity of data breaches and operational outages.

B2. Recommended Countermeasures

1. Remove Domain Admin rights from all standard IT workstations.
   Implement Privileged Access Workstations (PAWs) for administrative tasks.
   Require separate accounts for daily use and privileged operations.
   Adopt Just-In-Time (JIT) elevation for administrative actions.
   Delegate specific administrative permissions rather than granting full Domain Admin membership.

2. Segment the data center into separate VLANs or subnets based on system sensitivity (e.g., finance, customer data, application servers, management).
   Deploy internal firewalls or micro segmentation to restrict east-west traffic.
   Enforce least privilege network access, allowing only required ports and protocols between systems.
   Place the web interface in a DMZ to isolate externally reachable components from sensitive internal systems.
3. Deploy IDS/IPS at key network boundaries, including between corporate and data-center segments.
   Implement east-west traffic monitoring or micro-segmentation with inspection capabilities.
   Centralize logs into a Security Information and Event Management (SIEM) platform for correlation and alerting.
   Deploy EDR on servers and workstations to detect malicious behavior.
   Establish incident-response workflows and alerting thresholds to ensure timely action.

B2a. How Each Countermeasure Improves Security

1. Privileged Access Workstations (PAWs) isolate administrative activity from everyday user tasks, preventing phishing, malware, and browser-based attacks from reaching Domain Admin credentials.
   Separate admin accounts ensure that privileged credentials are used only when necessary and are never stored on standard workstations.
   Just-In-Time (JIT) elevation limits the time during which elevated privileges are in effect, reducing the opportunity for attackers to steal or misuse them.
   Delegated permissions reduce the number of tasks that require full Domain Admin rights, thereby shrinking the attack surface. A full-tunnel VPN ensures that all remote traffic is

inspected, reducing exposure to compromised home networks. It enforces consistent security policies regardless of user location.

2. Network segmentation limits lateral movement by separating sensitive systems (finance, customer records, application servers) into distinct trust zones.
   Internal firewalls or micro-segmentation enforce strict access rules between systems, ensuring that only required communication is allowed.
   Least-privilege routing reduces unnecessary connectivity, shrinking the attack surface and limiting the blast radius of a compromise.
   DMZ placement for the web interface isolates externally reachable components from internal systems, reducing exposure to internet-facing threats.

3. IDS/IPS identifies and blocks suspicious network traffic at key boundaries.
   East-west traffic monitoring detects lateral movement attempts inside the network, which are common in modern attacks.
   SIEM log aggregation correlates events across systems, enabling early detection of anomalies, credential misuse, or unauthorized access.
   Endpoint Detection and Response (EDR) provides behavioral monitoring on servers and workstations, catching threats that bypass perimeter defenses.
   Incident-response workflows ensure alerts are acted on quickly and consistently

C. Operational Environment Security Posture Evaluation

C1. Proposed Tools or Configurations

1. **Centralized Security Information and Event Management (SIEM)**
   Current logs are stored locally and reviewed infrequently. A SIEM would aggregate logs, correlate events, and provide real-time alerting. This centralized approach enhances the organization's ability to detect suspicious activities quickly, respond to incidents effectively, and maintain compliance with regulatory requirements.

2. **Endpoint Detection and Response (EDR)**
   Endpoints currently generate local antivirus alerts that "do not forward those alerts to a central console." EDR provides behavioral monitoring, automated containment, and centralized visibility. It enables proactive threat hunting, rapid isolation of compromised devices, and detailed forensic data collection to support incident response.

C2. Justification for Each Proposal

- SIEM improves detection by correlating events across systems, enhances response by providing real-time alerts, and supports recovery by maintaining long-term log retention. It also facilitates compliance reporting and forensic investigations.

- EDR strengthens detection through behavioral analytics, improves response by isolating compromised endpoints, and enhances recovery by providing forensic data. It complements traditional antivirus by detecting advanced threats that signature-based tools might miss.

D. References

National Institute of Standards and Technology. (2018). *NIST Special Publication 800-52 Revision 2: Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations.*

National Institute of Standards and Technology. (2020). *NIST Special Publication 800-57 Part 1 Revision 5: Recommendation for Key Management.*

International Organization for Standardization. (2022). *ISO/IEC 27002: Information Security Controls.*